Computer Standards & Interfaces 95 (2026) 104038

Contents lists available at ScienceDirect

Computer Standards & Interfaces

journal homepage: www.elsevier.com/locate/csi

Blockchain beyond immutability: Application firewalls on ethereum-based platforms

Christian Delgado-von-Eitzen *, Manuel José Fernández-Iglesias, Luis Anido-Rifón, Fernando A. Mikic-Fonte

atlanTTic – University of Vigo, Campus Universitario S/N, Vigo, ES-36310, Galicia, Spain

ARTICLE INFO

Keywords:
BAF
Blockchain application firewall
Dynamic access control
General data protection regulation
Privacy
Scalability, security

ABSTRACT

Blockchain is a technology that gained relevance in various fields due to its transparency and security in recording information in a reliable and immutable manner. In particular, the adoption of private blockchain platforms based on the Ethereum technology grew significantly in enterprise environments. However, there are certain issues concerning privacy and access control that may pose significant challenges in scenarios where private transactions occur between user agents instead of nodes, that is, between blockchain accounts that are not necessarily attached to specific nodes. The Blockchain Application Firewall (BAF) is introduced as a conceptual framework that can be applied in cases where control over data access is needed, including private transactions between accounts. More specifically, the BAF is intended to complement a blockchain endpoint acting as an intermediary between users and blockchain services and data, monitoring and controlling incoming and outgoing traffic, according to an applied access policy. This work investigates BAF's feasibility and effectiveness in enhancing the capabilities of Ethereum-based blockchains in the described scenarios. A proof-of-concept was implemented with Besu to assess its feasibility, providing evidence that BAF can act as an additional layer of control over data stored, helping to solve key limitations in practical implementations and allowing exploration of new use cases that could not be addressed so far.

1. Introduction

Blockchain technology appeared as a disruptive solution to support decentralized digital currency, known as cryptocurrency [1,2], by enabling transparent and independent data storage and utilization without relying on centralized control.

At its core, a blockchain is a distributed database that stores transaction records in a cryptographically secure, immutable, and permanent manner. Each block of data, containing transactions, is cryptographically linked to the previous block, forming an immutable chain (blockchain) that reflects the complete history of transactions. Additionally, some blockchain platforms allow the deployment and use of smart contracts [3], which are autonomous computer programs that run on a blockchain and automate the execution of certain conditions and actions defined in the program's logic. These smart contracts are developed in different programming languages, such as Solidity in the case of Ethereum [4]-compatible blockchains [5], and are executed automatically on a secured virtual machine when certain predefined conditions are met.

Smart contracts revolutionized the way in which digital transactions are executed by eliminating the need for intermediaries and ensuring the transparent and reliable enforcement of agreements among the involved parties, with all the managed information being reliably and immutably recorded on the blockchain. Their innovative feature of automatically executing actions based on verifiable data makes them a powerful tool for a variety of applications, such as digital asset management [6], supply chain control [7], trust management in the educational sector [8], healthcare [9], banking [10] or even the creation of financial products such as loans [11], but in a decentralized manner (i.e., Decentralized Finance or DeFi applications [12]), to name a few examples.

Blockchains can be classified in three broad types according to how access and control over the network is managed, that is, according to who is allowed to participate in the network and how control and access privileges are granted and revoked: public, private, and federated. Public chains, such as Ethereum [4] and Bitcoin, are accessible to

* Corresponding author.
E-mail address: christian.voneitzen@det.uvigo.es (C. Delgado-von-Eitzen).

https://doi.org/10.1016/j.csi.2025.104038
Received 19 December 2024; Received in revised form 30 April 2025; Accepted 23 June 2025
Available online 23 June 2025
0920-5489/© 2025 The Authors. Published by Elsevier B.V. This is an open access article under the CC BY-NC-ND license (http://creativecommons.org/licenses/by-nc-nd/4.0/).

anyone who can create a network node or participate in the network, being allowed to view any data on the chain and even potentially validate transactions and creating chain blocks [1]. A node is any computing device with the ability to store and validate information contained in the blockchain. Depending on its role, a node may participate in the validation of transactions, the execution of smart contracts or act as an interface that exposes services to external users. Public blockchains are known as permissionless networks, since it is not necessary to be granted permission to connect to them to send transactions or access stored information.

In turn, private chains are restricted to a specific set of authorized users and are primarily used in enterprise environments for internal applications. These are known as permissioned platforms because users who would like to connect or to create new network nodes must be granted permission to do so. As a relevant example of these chains, the Hyperledger initiative promoted by the Linux Foundation allows the creation of such blockchains [13] by means of HyperLedger Fabric [14] and HyperLedger Besu [15]. GoQuorum [16] is another popular platform that supports permissioned blockchains. In enterprise blockchains, nodes are typically managed by participating entities.

In addition to public and private blockchains, there is a third approach known as federated or consortium blockchains, which are controlled by a group of entities, organizations or companies, providing shared control and access within the consortium. Being governed by a closed group of entities, they are also permissioned in the same way as private blockchains are, and consequently authorization is required for users to connect or create a node. However, in this type of chains, it is not rare that the information managed, or parts thereof, are open to the public.

Blockchains in general, and Ethereum-based [4] blockchains in particular, demonstrated to be a revolutionary technology for ensuring data integrity, availability and traceability in various environments. However, their original design presents significant limitations in enterprise applications, especially in terms of dynamic access control and data privacy. While node-level privacy solutions exist, there is a lack of mechanisms for account-level privacy enforcement in Ethereum-based platforms. In enterprise environments, where confidentiality and restricted access to certain data are a common requirement, existing technologies (e.g., Tessera [17] on Ethereum-based platforms) facilitate privacy at the node level but do not provide the granularity needed to dynamically manage access at the account level (i.e., for individual users or smart contracts). As illustrated with the examples below (cf. Sect. 2.3 and Sect. 4.4), these limitations justify the introduction of alternate approaches to deal with scenarios that, due to privacy issues, prevented the introduction of blockchain platforms.

This paper introduces the Blockchain Application Firewall (BAF), a conceptual framework designed as an Application Programming Interface (API) between a blockchain account and the node that exposes the blockchain's JavaScript Object Notation Remote Procedure Call (JSON-RPC) service. The BAF is designed to enhance the functionality of permissioned blockchain platforms by incorporating advanced, dynamic and granular access control mechanisms. Unlike existing solutions for conducting private transactions that operate primarily at the node level, the BAF supports flexible access policies at the account level (i.e., for specific users, roles or smart contracts). In addition to access control, the BAF supports additional functionalities, such as a logging system to audit requests and responses for regulatory compliance (e.g., compliance with the General Data Protection Regulation (GDPR) [18]), private responses based on cryptographic techniques such as zero-knowledge proofs and Pedersen commitments [19], and the ability to dynamically adapt to changes in access policies without the modification of already deployed smart contracts. The BAF may also incorporate caching mechanisms to improve system scalability and performance, avoiding redundant queries to the blockchain, protecting against unauthorized access by filtering suspicious requests or preventing Denial-of-Service (DoS) attacks. The BAF can also be integrated with identity management systems to dynamically authenticate and verify user permissions. These features make the BAF a versatile solution, especially suited for enterprise environments, addressing privacy, scalability and security constraints, while enabling new use cases and facilitating regulatory compliance.

The remainder of the paper is organized as follows: Section 2 reviews related works and provides the motivation for this research, analyzing relevant technologies and underscoring why existing solutions fail to fully address certain application scenarios that the BAF is designed to handle. Section 3 introduces the proposed BAF model, detailing its core functionalities. In Section 4, a proof of concept is presented to demonstrate the BAF's technical feasibility, together with a real application example. Section 5 analyzes the results and discusses their broader implications, while Section 6 concludes the paper by outlining future research opportunities.

2. Background, related work and motivation

2.1. Background

Blockchain platforms inherently ensure data security through their cryptographic foundations, particularly for recording and verifying information authenticity. This design feature guarantees secure and tamper-proof records, as demonstrated in cases such as the use of a blockchain for recording firewall data [20]. However, due to the decentralized nature of public blockchain technology, it lacks mechanisms to restrict data queries, as trust stems from its transparency and resistance to censorship, ensuring that information is accessible to "everyone" (i.e., anyone in a public blockchain; other authorized nodes or users in the case of private or consortium blockchains). This is an advantage for use cases such as payment methods or platforms where information is meant to be openly shared, promoting transparency and trust. On the other hand, enterprise and private blockchains incorporate mechanisms to control access to data, ensuring that only authorized nodes can view or interact with the information. This tailored access control makes them more suitable for scenarios where data confidentiality and restricted visibility are essential. Presently, there are few initiatives addressing this issue, mainly because including selective data access techniques could be perceived as disregarding blockchain's foundational principles, although there is an actual need to guarantee the privacy of certain transactions or information in business-related use cases.

2.2. Related work

We can find in the literature some relevant works addressing the situation described. For example, Zyskind et al. [21] proposed a blockchain-based system to improve privacy and protect data, where only the owner is allowed to access such data. However, it did not provide the possibility of granting access to other users.

Di Francesco Maesa et al. [22] proposed using blockchain technology to manage access rights to resources in the Bitcoin platform and transfer them from one user to another by means of policies written in the extensible access control markup language (XACML). In later publications [23,24], they considered the introduction of smart contracts in their solution, but they did not address privacy issues.

Xu *et al.* [25] proposed a blockchain-based access control system using an information exchange scheme that protects information through ring signatures [26]. They demonstrated its feasibility by constructing a prototype with Hyperledger Fabric using channels, because in this blockchain framework, channels are predefined communication paths between certain specific members, so that transactions and related data are only visible to them. This feature undoubtedly adds a layer of privacy and data access control, but it is specific to Hyperledger Fabric blockchains and does not support Ethereum-based private or consortium blockchains. Xu's proposal relied on the Hadoop Distributed File System

[27] as the preferred storage solution.

On the other hand, Corda [28], a blockchain platform designed primarily for financial and business applications, relies on a distributed data model among participating entities that supports private transactions among them, ensuring data confidentiality through advanced cryptographic techniques while providing a high degree of flexibility in granting access permissions. Corda does not use Turing-complete smart contracts as Ethereum Virtual Machine (EVM) blockchains [29] but digitized legal contracts to enforce agreements and validations between specific parties. This orientation makes it particularly suitable for environments where privacy and interoperability are critical, such as the financial and business sector, although this constraint could hinder the development of highly customizable or automated applications that require complex logic, such as decentralized finance (DeFi) protocols [30] or tokenized asset management systems. Additionally, lacking a single shared blockchain may complicate inter-entity transactions and the establishment of a unified trust layer, reducing its adaptability to use cases demanding broad interoperability among multiple stakeholders. While this approach makes Corda particularly suitable for environments where privacy and regulatory compliance are a basic requirement, it lacks versatility to support general-purpose decentralized applications (dApps [31]).

Media Lab's ChainAnchor [32] focuses on providing anonymous verifiable identities for entities connecting to a shared permissioned blockchain through zero-knowledge proofs [33]. This allows for the creation of an access control mechanism executed by the consensus nodes. While this is a relevant proposal, it remains at a conceptual model stage and lacks a practical implementation that could be tested, as it requires significant changes in how blockchain networks manage identity and access.

Alniamy and Taylor [34] proposed a model architecture that provides access control for data stored in the cloud, instead of another blockchain, by combining blockchain technology (i.e., Hyperledger) with an attribute-based encryption scheme (ABE [35]). Encrypted data is stored in the cloud and a hash summary on the blockchain, and access is controlled with smart contracts (i.e., chaincode in Hyperledger terminology), granting or denying access. Note that this is not actually the same scenario, as it assumes that not all data can be stored on a blockchain due to privacy concerns, not even in encrypted form [36–38].

Jemel and Serhrouchni [39] suggested using blockchain as a platform to implement a shared access control management system, and they implemented a prototype using the Multichain platform and the Ciphertext-Policy Attribute-Based Encryption (CP-ABE) access control scheme. Similarly, in [40] a model and prototype for role-based access control (RBAC) is introduced using smart contracts (RBAC-SC) on Ethereum to achieve role utilization among organizations, modeling the essential trust relationships in RBAC and implementing a challenge-response authentication protocol that verifies user role ownership. In both cases, although the approach focuses on access control using blockchain, it does not aim to enhance data security and privacy within the blockchain itself, as the BAF does.

In [41] a firewall for blockchain applications called ChainGuard is presented, using software-defined networking (SDN) technologies with OpenFlow. This firewall is designed to filter network traffic to effectively mitigate DoS and distributed DoS (DDoS) attacks and protect the blockchain platform at the network level. Similarly, BlockFW (a blockchain-based rule sharing firewall) proposed by [20] primarily protects the security of networks and computer systems through its approach of creating a blockchain-based firewall. It uses this technology to decentralize validation and verification using multiple nodes, improving availability, and maintaining the integrity of rules if they are stored on the blockchain and signed by legitimate authorized users. In [42], blockchain is also used to implement access control in the Internet of Things (IoT). Again, these publications focus on using blockchain to enhance the security of other elements, not the information recorded on the blockchain itself.

2.3. Motivation

As introduced in Sect. 1, there are three main types of blockchain platforms, namely public, private and federated or consortium blockchains. Although blockchains have relevant advantages, such as immutability and transparency, guaranteeing information privacy and managing data access still pose significant challenges. In the case of public blockchain-based cryptocurrencies [43] like Bitcoin or Litecoin[1] intended to serve as payment methods, it should not be problematic from an information balance standpoint to be visible to everyone, although there are alternatives like Monero,[2] ZeroCash,[3] or Grin,[4] to mention some examples that focus on protecting user privacy. However, for permissioned platforms (i.e., private or consortium) where enterprise applications with organizational information are deployed (e.g., medical, academic, supply chain, etc.), data must be protected from unauthorized access and its security and privacy must be ensured if the application is to be used in production environments.

Unlike public blockchains where participants are anonymous and cannot be trusted, both private and consortium blockchains follow a permissioned model where the underlying blockchain nodes are known and have known cryptography-protected identities, which should make them secure. In this paper, the focus is set on permissioned platforms based on Ethereum's technology, such as Hyperledger Besu or GoQuorum [44], which implement private transactions by means of Tessera [17], a privacy manager enabling secure and private transactions by managing encrypted communication and private states between nodes.

A private transaction is not visible to all network participants. Instead, it represents a special type of transaction that can be sent directly to the mining nodes, thus avoiding inclusion in the blockchain's mempool and preserving its confidentiality [15]. In contrast, conventional transactions are sent to Ethereum nodes through the underlying peer-to-peer network, with all nodes eventually inserting it into their mempools.

Tessera is a component specifically designed to provide private transactions on permissioned blockchains based on the Ethereum ecosystem, in particular on platforms such as GoQuorum and Hyperledger Besu, although additional platforms may be supported in the future. It functions as a privacy and confidential data management mechanism, allowing certain transactions to be accessible only to authorized participants. In this context, only selected nodes receive and validate transactional information, thus ensuring granular control over data visibility and confidentiality in restricted-access blockchain networks.

In GoQuorum, an enterprise Ethereum-based platform developed by JPMorgan and currently maintained by Consensys, Tessera is tightly integrated to provide the necessary transaction privacy. When a user sends a private transaction, it is encrypted and accessible only to specific recipient nodes, ensuring that other nodes on the network do not have access to the transaction information. Hyperledger Besu, another permissioned Ethereum solution discussed above, also supports the use of Tessera to implement transaction privacy, although Besu allows for more flexible approaches, such as Flexible Privacy Groups, which facilitate the dynamic modification of which participants have access to specific transactions after the creation of the group.

Tessera allows private transactions to be kept separate from the chain accessible by all nodes in the peer-to-peer network and notarized therein, thus achieving an effective privacy layer in enterprise environments although, as expected, these private transactions are not stored on-chain. Besides, it has additional limitations. Its focus is on inter-node privacy, which implies that data from a private transaction is

[1] https://litecoin.org/
[2] https://www.getmonero.org
[3] https://z.cash
[4] https://grin.mw

only visible to specific nodes in the network. In scenarios where more granular access control is required, such as restricting access at the user level, to specific accounts, or specific roles within an organization, Tessera does not offer native mechanisms to manage these complex requirements. Furthermore, it does not support the revocation of permissions, since once the private transaction is created, the details of the transaction are shared and visible to the participating nodes via peer-to-peer encryption. This implies that since the receiver already has a copy of the data, the permission cannot be revoked. Flexible Privacy Groups increase flexibility by allowing members of a privacy group to be added or removed, but the removal of a node does not retroactively affect previously granted access; changes only affecting future transactions. Depending on the specific use case, this feature may or may not be problematic.

An example situation could help differentiate the two scenarios. First, consider a network of companies engaged in international trade using a blockchain platform to manage sales and logistics contracts, which in turn are supported by an Ethereum-based blockchain with private transactions provided by Tessera. In this scenario, two companies (e.g., Company A and Company B) wish to conduct a private transaction, such as negotiating terms of an export contract or exchanging confidential pricing and terms information. Tessera allows the details of this transaction to be visible only to the peer-to-peer nodes hosted by these two companies, while other nodes in the network (e.g. trading partners or regulatory authorities) would not have access. The transaction data is fully encrypted and protected and is only shared exclusively to the authorized nodes, ensuring confidentiality between the authorized companies.

Second, consider a group of companies that share a private blockchain for project management where everyone has their own account. A project manager in the Finance department needs to share confidential budget information with a subset of accounts in several companies only (e.g., a group of financial analysts), excluding other users in the same or other departments. Private transactions among specific user accounts cannot be implemented with Tessera. Although Tessera's technology can ensure privacy between nodes hosted by the different companies or departments, it does not offer native tools to restrict access at the level of individual accounts within a single node. To address this need, which is common in corporate environments, alternate solutions need to be integrated.

In this context, complementary technologies, such as the Blockchain Application Firewall introduced in this article, are needed to provide more granular privacy and data access management for Ethereum-based blockchains, extending privacy capabilities beyond interactions between the underlying network nodes. The BAF acts as an intermediate layer that enables more dynamic and precise access policies, ensuring that only specific accounts, users or roles have access to certain transactions or data assets, including additional functionalities such as logging read-only accesses to the blockchain, without relying solely on the node-level privacy provided by Tessera. Besides, the BAF also supports the dynamic granting and revocation of access permissions in a flexible way.

In any case, it should be noted that these are complementary and non-exclusive technologies, so that they can be applied simultaneously if the use case so requires, which opens the door to new alternatives when developing blockchain-based solutions with stringent data access requirements.

To sum up, as pointed out above, the focus of the proposed solution lies on permissioned Ethereum-based blockchain platforms such as Hyperledger Besu and GoQuorum blockchains. For those scenarios in which transactions must be kept private among certain nodes, Tessera is a fully integrated solution with Hyperledger Besu and GoQuorum to address private transactions between nodes. For cases where private transactions should be performed among user agents (e.g., accounts or smart contracts), the Blockchain Application Firewall is proposed as a conceptual framework conceived as piece of software that monitors and filters incoming and outgoing traffic to and from a blockchain, ensuring that only authorized requests are allowed, and that unauthorized traffic is blocked. Unlike traditional firewalls that operate at the network level, the BAF inspects the data packets at the application layer, such as smart contract invocations and their responses, and transaction requests and their outcomes. The BAF will enforce policies based on context, providing a higher level of security and privacy by understanding the specific behaviors and requirements of the blockchain application. This granular level of control helps in mitigating the issues identified above.

As the BAF is mainly oriented to enterprise use cases, it could be argued that using permissioned blockchains such as Hyperledger Besu, GoQuorum or similar, which implement mechanisms to restrict unauthorized access at the node level, might be enough. However, note that the mentioned blockchain platforms do not support the fine-grained, flexible and dynamically configurable access control features offered at the level of individual accounts or smart contracts by the BAF beyond nodes, which in turn is a requirement in certain scenarios (cf. Sect. 3).

Additionally, the feasibility and effectiveness of the BAF in the considered context is analyzed, as well as its ability to provide an additional layer of security, privacy, and control over the data stored on a blockchain. Additionally, a proof of concept and a real application example are introduced using Hyperledger Besu to demonstrate a practical BAF implementation and a possible application.

3. Contribution

Our focus is to conceptualize a framework, a Blockchain Application Firewall in a broad sense, aiming to enhance information privacy in a private or consortium Ethereum-based blockchains in those cases that cannot be addressed by the incorporation of Tessera as discussed in Sect. 2.3, to enable dynamic access control, and generally improve the scalability and security of blockchain-based solutions, among other additional features. As previously discussed, the inherent security-related characteristics of blockchain technology ensure that the information stored and recorded in transactions, which are registered in cryptographically linked blocks, cannot be maliciously altered. This maintains integrity, authenticity, and non-repudiation, thanks to the leveraging of cryptography. Besides, blockchains are characterized by their high availability, as transactions are distributed across a peer-to-peer network of nodes. While not all nodes may hold the same information (e.g., light nodes in public blockchains or nodes with restricted access in permissioned networks), the distributed nature of the network ensures high data availability and resilience.

Other security dimensions, such as confidentiality and access control, cannot be strictly enforced in all possible blockchain scenarios, although mechanisms like wallet-based authentication and user permissions can provide these features in certain contexts, such as business blockchains. Note that trust in this decentralized solution comes from the fact that the information is deemed correct by a sufficiently large number of honest nodes that contain (all) the valid data, without a centralized entity coordinating or determining the validity of information. The fact that information is accessible to all nodes is a characteristic of public blockchains, distinguishing them from traditional platforms. However, in enterprise or business blockchains, nodes are typically supervised, access can be restricted, and transactions may be encrypted, making these environments more suitable for scenarios where data confidentiality and selective access are required. If large amounts of unencrypted data are stored and made available to all participants on a public blockchain or private blockchain without adequate protection mechanisms, it is possible to obtain and analyze this data using advanced analytical techniques, which could reveal sensitive information using pattern recognition or statistical inference. For example, reducing the size of anonymization groups by correlating unrelated data points may facilitate the reidentification of individuals or transactions. However, enterprise-level blockchain systems typically incorporate robust inter-node access controls, data encryption and other

privacy mechanisms to mitigate these risks and ensure data confidentiality.

Blockchain platforms can be deployed that support private communications (e.g., private transactions in Besu or GoQuorum [45] as introduced in Sect. 2.3), The main issue of these private communication channels is that they operate among the nodes in the peer-to-peer network and cannot discriminate among specific user agents once permission is granted to a node, which limits the flexibility of this approach in certain scenarios in which users must have dynamic, flexible, and agile access mechanisms to the data stored on the blockchain in a configurable and highly dynamic manner.

From the developer's perspective, the BAF is an API that introduces a dynamic and granular access control mechanism for these cases where private transactions are not limited to specific nodes, which overcomes the limitations of traditional permissioned blockchains, Besides, it adds some additional functionalities that improve some features of private or consortium platforms, as below.

To illustrate the applicability of the BAF in comparison to other Ethereum-based blockchain privacy control solutions, a methodological approach to evaluate privacy and access needs was developed to identify the most suitable solution. The decision logic below illustrates how BAF integrates into specific business scenarios, differentiating itself from tools such as Tessera on GoQuorum or Besu when dynamic and granular control is required. The logic evaluates scenarios where private transactions are not limited to specific nodes and need additional flexibility to meet advanced requirements. Besides, two additional use cases are introduced showcasing a complementary BAF application, namely the logging of read-only operations and when node-level privacy is sufficient but additional features such as those described in this section can be provided by the BAF as an enhancement. In Fig. 1, a methodology is outlined to determine when to use or not a BAF.

Our first concern is to define a versatile model to enable the creation of a dynamic and flexible access control mechanism for data in the scenarios discussed, at the cost of partially compromising one of the properties of blockchain platforms, namely decentralization, by introducing controlled access points. However, as discussed below, decentralization is already compromised in private blockchains, and the benefits in terms of security, compliance, and flexibility outweigh this tradeoff. Additionally, as illustrated by the decision logic above in Fig. 1, there are other features that can be implemented by the BAF beyond of access control.

It is important to keep in mind that, when a user agent connects to a platform that uses a blockchain, they never connect directly. Instead, they must submit a request to one (or several) of the nodes that are part of the underlying peer-to-peer network, and these requests are responded by services exposed by these nodes. The BAF acts as an intermediate element between the user agent's device and the blockchain node that processes queries. Unlike conventional interfaces used in IoT [46] or VANET [47] systems to name some examples, the BAF offers more than just a connection layer; it provides a dynamic access control mechanism in the considered scenarios, enhancing data privacy, enabling selective information sharing, and facilitating compliance with regulatory standards such as the GDPR. This versatility makes the BAF particularly valuable in enterprise scenarios where granular control, real-time adjustments to permissions, and comprehensive audit trails are required.

The proposed scheme is outlined in Fig. 2, where the main elements could be visualized. Under normal conditions, a third party (T) connects directly to the node through a series of exposed services, such as a JSON-RPC API providing Web3 services, as is available in Ethereum, for example [48]. Other blockchain platforms expose similar services.

The caveat, as pointed out above, is that while smart contracts and blockchain logic often restrict the storage of new data or the modification of existing data, they do not prevent data from being read by duly authorized nodes. In public blockchains, this can lead to potential privacy issues, as any user can query the data stored on the blockchain. However, in the case of permissioned platforms, which is the focus of this article, access to data is often restricted to authorized nodes, but privacy issues still arise when dealing with private transactions that require selective data sharing beyond the peer-to-peer nodes involved in those transactions. In such scenarios, the BAF allows filtering third-party requests and allowing or denying access according to an advanced access control mechanism. For example, the BAF can apply filtering rules that determine whether a third party can access the state of a specific smart contract, based on predefined parameters and access permissions.

Filtering rules can be part of the BAF logic as static or dynamic rules, configurable by administrators or authorized users. They can be obtained from an internal BAF database, an external rule repository, or even stored on the blockchain itself to enhance system's transparency and promote trust. By leveraging blockchain events, the BAF can be configured to listen to events emitted by controlled smart contract to stay updated on changes to the access list, ensuring that the BAF is always synchronized with the most recent information on the blockchain, to avoid inconsistencies.

With this model, the BAF only analyzes the rules that it manages, regardless of where they are stored, and proceeds with their enforcement. Thanks to this fine-grained, dynamic permission control, the BAF can significantly prevent any user from accessing all available information by applying selective transparency. This facilitates compliance with specific regulations and standards, such as personal data protection regulations, by applying appropriate access and security policies in interactions with the blockchain. Depending on the type of information being managed, the BAF could even return query responses without revealing actual data using privacy preserving techniques like Pedersen Commitment [19], which are cryptographic primitives that allow committing to a value while keeping it hidden, yet enabling later verification, and zero-knowledge proofs [49], which also enable proving possession of a secret without revealing it. Both are promising techniques for applications where sensitive data must remain hidden and, at the same time, transactions and information must be guaranteed to be correct. For example, if a user wants to check the balance of a specific account on the private or consortium blockchain and the BAF has a rule to only indicate whether the balance is greater than zero, the user will receive only that specific information. This approach ensures that sensitive data remains protected.

One of the major drawbacks of existing blockchain technology is that the absence of query logging can make auditing challenging, especially in enterprise environments where tracking who accessed certain data is critical for compliance, as they do not change the state of the blockchain as data modifications do. Reading stored data does not require consensus either, but the information will be provided directly by the node receiving the query, or at most the closest one with a full copy of the chain, which in turn can be a problem in certain use cases. For example, consider a system for issuing and validating academic information using blockchain [36], which must comply with the GDPR [18], and does not store on-chain personal data but just evidence that the academic information is, while the holders of that academic information may grant and withdraw permissions to third parties. To guarantee GDPR compliance, it is necessary that both permission grants and revocations are properly recorded and, also, that a record is kept of the queries made to the blockchain by the users authorized to access the information. In the absence of the BAF, these read-only operations could not be notarized.

In such situations where any access must be audited including read-only queries, the BAF can offer a solution. Note that the BAF can log and audit all transactions that pass through the firewall, providing complete traceability for all activities performed on the blockchain, and thus facilitating the detection and resolution of problems or disputes. Furthermore, periodically storing access logs or at least a hash summary of them on the blockchain can prevent BAF administrators or hackers from tampering with log information without being detected.

Even if personal data is not directly stored on the blockchain, such data analysis could yield information that could be deemed personal and

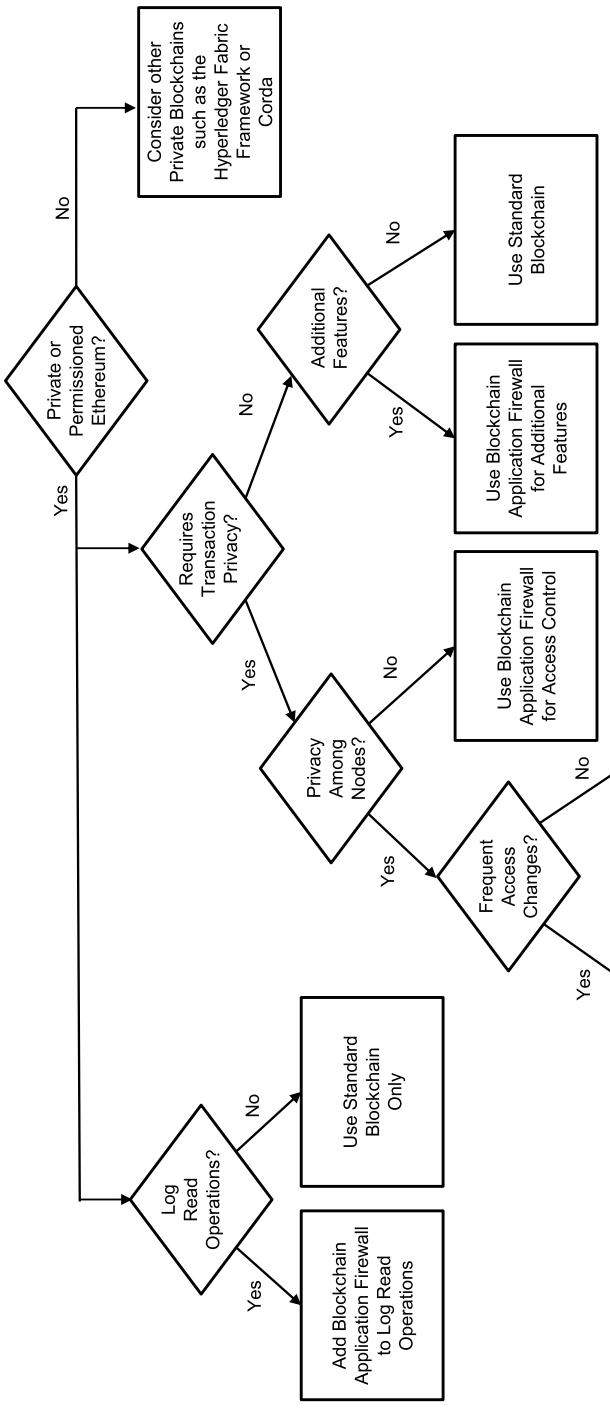


Fig. 1. This flowchart outlines the decision-making process for implementing the Blockchain Application Firewall (BAF) in various scenarios, guiding users to determine the optimal configuration through considerations such as logging support, privacy requirements, permissioning, or access control.

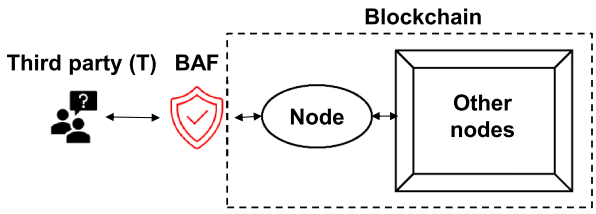


Fig. 2. Proposed access scheme. The BAF serves as an intermediary between external apps and blockchain data, selectively handling access and privacy.

therefore should be access-restricted to comply with data protection regulations, such as the above-mentioned GDPR in Europe, one of the strictest data protection regulations in the world. Note that introducing BAF does not guarantee that the resulting system will comply with the GDPR or similar regulations, but it certainly contributes to improve such compliance with features that cannot be provided by standard blockchain technologies, as the BAF provides mechanisms to guarantee that only duly authorized users can access certain data, so that information holders can grant and withdraw permissions according to their wishes at all times in a dynamic and flexible way, something that cannot be achieved in permissioned blockchain platforms in this context. Besides, the BAF makes it possible to log read operations on the blockchain to provide data access accountability. Blockchain platforms implement secure mechanisms to record transactions modifying the state of the chain, but they lack native mechanisms to log read-only transactions that do not change the state of the chain.

In the following paragraphs, we point out other enhancements that the BAF can bring to a system, which are identified in the decision logic above (cf. Fig. 1) as "other features".

An additional enhancement comes from the integration of BAF with identity management systems, which aim to improve the verification and authentication of user agents accessing the blockchain. While Ethereum-based platforms such as Besu or GoQuorum use authentication mechanisms through wallets and role-based access controls, these mechanisms generally enforce restrictions and permissions at the level of smart contracts and private transactions between nodes. In contrast, BAF provides a more dynamic and flexible approach, allowing granular access control and policy enforcement that is not statically fixed between specific nodes. This ensures that only authorized individuals can access or interact with specific data, integrating verified digital identities that can adapt to changing access requirements and organizational rules, providing a significant advantage for business scenarios that require selective data exchange.

While peer block and transaction validation ensure the integrity and consistency of data on the blockchain once recorded, BAF introduces an additional layer of data pre-validation specifically for cases involving external data sources (e.g., oracles or other data repositories). This step verifies the authenticity and integrity of external data before writing it immutably to the blockchain, ensuring that only validated and trusted information is recorded. This complements existing protections provided by smart contracts and network consensus mechanisms, addressing potential vulnerabilities associated with data inputs from external sources.

In addition to restricting external access to any content stored on the blockchain, and therefore enhance privacy through access control, the BAF could also offer other security services supported by specific access rule configurations. For example, BAF access control rules could be defined dynamically by means of an Artificial Intelligence (AI)-powered module trained to enhance network security [39,41,50–52]. These AI-enhanced firewalls learn iteratively, improving their effectiveness over time. In general, one of the main characteristics of next-generation firewalls is the integration of AI technologies [34]. By incorporating such AI capabilities, the BAF can iteratively learn and adapt to new security threats, offering a robust and evolving security solution for blockchain platforms.

BAF can also leverage Software-Defined Networking (SDN) [41] capabilities to enhance protection against DoS attacks that could affect the performance and availability of the blockchain, thereby ensuring its continuous and reliable operation. By utilizing the SDN centralized control, the BAF can monitor network traffic in real time, identify anomalous or malicious patterns that may be indicative of a DoS attack, and respond by dynamically reconfiguring network flows to mitigate the attack. This may include rerouting, rate limiting or blocking suspicious traffic before it can affect the performance and availability of the blockchain network, thus ensuring continuous and reliable operation. In this same line of action, the BAF could also be used to filter or block specific transactions that do not meet certain predefined criteria, such as suspicious addresses or repeated requests following certain detected patterns. While smart contracts are designed to apply rules and conditions to transactions directly on the blockchain, the BAF complements these capabilities by providing an external layer of transaction filtering and control. This allows for dynamic adjustments to access policies and filtering rules without modifying the smart contracts, enabling more agile handling in situations such as suspicious addresses or unusual patterns of repeated requests. By operating outside of the blockchain's internal transaction logic, the BAF can prevent fraudulent or malicious activity in a more flexible and efficient manner, improving the overall performance and scalability of the system.

Incidentally, the performance and scalability of the BAF can also be improved by using a cache. By caching certain queries, such as the most frequent ones or those meeting specific requirements modeled as rules, the BAF can improve the response speed of blockchain-based systems. This eliminates the need to query the nodes directly, allowing results to be obtained faster. This approach is inspired by existing literature on off-chain storage and caching strategies [47] aimed at improving blockchain efficiency. Note that the BAF is not intended to replace these mechanisms, but to complement them by providing an additional layer of optimization. Of course, this information should always be available by forcing a query in cases where there might be doubts about its authenticity or whether it is the latest version of the data. Smart contracts can be programmed to notify the BAF of specific data updates using events triggered by changes in the information, guaranteeing that the cache remains updated.

Regarding scalability, the BAF can optimize and prioritize certain incoming requests based on factors such as the origin addresses, the operations to be performed, or the destination smart contracts. By prioritizing critical or high-priority transactions, the BAF can ensure that essential transactions are processed faster, reducing congestion and improving the overall performance of the blockchain network. This dynamic management of incoming requests minimizes bottlenecks and enables more efficient use of network resources and avoids network congestion [20], which directly contributes to improved system scalability and responsiveness. Although this may eliminate some neutrality in the use of the blockchain platform, it can be beneficial for all users if done transparently and guaranteeing users' awareness.

In terms of network security enhancement, the BAF can be used to automatically detect and mitigate security attacks such as double-spending, forgery attempts, or transaction manipulation by monitoring incoming traffic and transaction patterns, and so, it would increase the protection and even the integrity of the blockchain platform. For example, it can apply predefined rules to identify suspicious behavior, such as repeated attempts to use the same transaction interactions and block these attempts before they reach the blockchain nodes. The BAF can also use dynamic blacklists to prevent transactions involving flagged addresses, thereby reducing potential risks. In addition, if an organization identifies problems with deployed smart contracts, the BAF can simplify release management by acting as an intermediary layer that redirects requests. This enables secure upgrades of non-upgradable smart contracts by changing requests from the original contract address to the updated version address, according to BAF rules, without

the need for direct modifications to the contract logic. This process is similar to existing upgradeable contracts [48], but eliminates the need for complex proxy logic within the smart contract itself, providing a streamlined and controlled upgrade path.

Thus, the BAF is proposed as a conceptual framework that introduces new capabilities for access control, privacy, scalability, and security in blockchain systems. While some of these capabilities were explored through a proof-of-concept that will be discussed in the next section, others represent potential applications that highlight the flexibility and scope of the BAF. The list of contributions below reflects this combination of proven capabilities and future lines of development, providing a framework for understanding how BAF can integrate with and enhance existing blockchain systems.

The contributions of this paper can be classified into the three thematic categories discussed below.

- **Privacy enhancements**
  This category covers mechanisms for enforcing selective data privacy at the account level, including BAF's conceptualization, request filtering, and integration with cryptographic commitment mechanisms.
  - BAF conceptualization. We propose the Blockchain Application Firewall as a middle-agent solution to improve information privacy in blockchains, enabling dynamic access control and improving the scalability and security of blockchain-based solutions in scenarios where privacy must be supported for certain transactions beyond the node level.
  - Access and privacy. The BAF filters third-party requests, allowing or denying access to data according to configurable and dynamic access control rules, facilitating the resulting system to become compliant with data protection regulations such as GDPR. However, note that the mere existence of BAF does not guarantee it.
  - Integration with privacy preservation techniques. BAF may implement techniques such as Pedersen Commitment and zero-knowledge testing to validate transactions without revealing sensitive data, enhancing privacy protection in enterprise environments.
- **Security & auditing**
  In this category, approaches to support secure operations, auditability, and identity verification are introduced, such as logging and notarization, access auditing, and AI-powered rule enforcement.
  - Auditing and access logging. The BAF can provide full traceability of activities on the blockchain by auditing and logging all transactions that pass through the firewall, storing hash summaries of records on the blockchain to prevent tampering.
  - Identity management. The BAF may be integrated with identity management systems to verify and authenticate users, ensuring that only authorized individuals access data or perform actions on the blockchain.
  - Enhanced security capabilities. The BAF may integrate artificial intelligence modules that iteratively learn and adapt to new security threats, providing a robust and evolving firewall solution for blockchain platforms.
- **Performance & extensibility**
  This category addresses system efficiency and adaptability through caching strategies, request prioritization, scalability optimizations, and smart contract version control.
  - Vulnerability mitigation. The BAF can protect against distributed DoS attacks by filtering or blocking suspicious transactions, which improves blockchain security and performance.
  - Improved performance through caching systems. The introduction of caching mechanisms improves response times in blockchain systems, reducing the need to query nodes directly.
  - Scalability optimization. The BAF can optimize and prioritize incoming requests based on various criteria, to avoid network congestion and improve resource efficiency.
  - Smart contract-based version control. The BAF facilitates the secure management and updating of smart contracts, allowing contract versions to be updated without disrupting operations.

4. Proof of concept and application example

To demonstrate the feasibility of the solution proposed, a proof of concept was developed in which a BAF receives user requests and forward them to the JSON-RPC service exposed by a node on a Hyperledger Besu [15] network deployed on the Azure cloud service. This proof of concept illustrates a scenario in which users may or may not access certain information at the account level, not the node level, which is the type of use case where the BAF provides a solution. Additionally, we illustrate the notarization of read queries, something that in a conventional blockchain, even a private one, cannot be done without middleware. The outcomes of the tests performed are also provided and analyzed in detail in Sect. 4.3, and the introduction of a BAF in a real-world application under development is discussed in Sect. 4.4.

4.1. Technical framework

The Hyperledger Besu blockchain platform was selected to deploy a proof-of-concept implementation for the BAF discussed in this paper, which in turn was developed in Node.js. Microsoft's Azure was the platform of choice to evaluate the BAF prototype.

As already introduced above, the Hyperledger Besu initiative is based on Ethereum, ensuring compatibility with smart contracts developed for the Ethereum Virtual Machine (EVM, [53]). It is specifically designed for creating private or consortium blockchain platforms, which, as already pointed out, are the most suitable for implementing a BAF in certain scenarios discussed in Sect. 3. Additionally, in line with this approach, Hyperledger Besu supports gas-free transactions except for the deployment cost of the smart contract itself. In other words, it is not necessary to pay for individual transactions even before they are completed, which is most convenient in private or consortium blockchains, as it allows for the generation of transactions without the need for continuously reloading account balances to operate.

Node.js is an open-source, cross-platform JavaScript runtime environment that executes JavaScript code outside of a web browser, designed for developing scalable and responsive applications. It utilizes an event-driven, non-blocking I/O model, making it efficient and suitable for real-time applications that require high throughput. Node.js is the preferred environment for developing decentralized applications, particularly those that interact with Ethereum-based blockchain platforms, due to several key features. Its asynchronous and non-blocking nature allows Node.js to handle multiple operations concurrently, which greatly facilitates the deployment of blockchain applications that require real-time data processing and interaction with multiple nodes. Besides, Node.js leverages the extensive JavaScript ecosystem by providing access to numerous blockchain, security and communication-related libraries and frameworks that, in our case, will simplify the development process of the BAF concept. For example, Hardhat[5] and Web3.js[6] are comprehensive development environments for Ethereum software that facilitate tasks such as smart contract compilation, testing, debugging, and deployment. These frameworks' integration with Node.js allows developers to use JavaScript to script and automate these tasks, enhancing productivity and ensuring a streamlined workflow.

Azure is a highly convenient platform for deploying a BAF proof-of concept based on Hyperledger Besu due to its robust infrastructure, scalability, and comprehensive support for blockchain technologies. Azure provides a flexible and scalable environment that facilitates the testing and development of blockchain applications that require

[5] https://hardhat.org
[6] https://web3js.readthedocs.io

dynamic resource allocation.

With Azure's Blockchain Service, developers can easily set up and manage Hyperledger Besu nodes, ensuring compatibility with Ethereum smart contracts and facilitating seamless deployment. Additionally, Azure offers integrated security features, such as Azure Active Directory and Azure Key Vault, which enhance the security and privacy of blockchain applications by providing secure identity management and key storage solutions. The platform's global network of data centers ensures low latency and high availability, which would be critical for maintaining the performance and reliability of a BAF. Furthermore, Azure's comprehensive suite of development and monitoring tools, such as Azure DevOps and Azure Monitor, enables efficient development, deployment, and management of blockchain solutions, making it an ideal choice for implementing a BAF proof-of-concept.

4.2. Proof of concept

To demonstrate the technical feasibility of the solution proposed in this paper, a proof of concept was developed with current available technologies in which a BAF receives user requests and forward them to the JSON-RPC service exposed by a node on a Hyperledger Besu [15] network deployed on the Azure cloud service. For this proof of concept, programmed in Node.js, the BAF's API exposes the following services:

1. An access control mechanism to check all requests made by a certain account to the service (e.g., source address, destination address, operation) against a set of rules configured in the BAF. Requests are allowed or denied based on these rules. If allowed, requests are sent to the node's JSON-RPC service for processing on the blockchain, to eventually get a response.
2. A local Log Registration and Blockchain Notarization (LRBN) mechanism, which enables the BAF to record all requests and responses in a local logger, which in turn is notarized every hour. A hash summary of the information is generated and stored on the blockchain. The registration functionality was developed in a way that minimizes delays (i.e., using libraries such as pino-http[7]) and provides a reliable mechanism to verify the integrity and authenticity of logged data, allowing for independent auditing and ensuring that no unauthorized modifications were made.
3. A service that restricts third-party access to exact account balances. Instead, it will return a binary response indicating whether the balance is zero (0) or greater than zero (1). The BAF detects a balance query request and, rather than providing the precise amount, simply confirms if the balance is non-zero, thereby enhancing data privacy and security.

The pseudocode for the access control mechanism (1) is as follows:

PROCESS REQUEST(request)

Extract source address, destination address, and operation from the request

IF the request matches the access control rules

Forward the request to the blockchain node for processing

RETURN "Request allowed and forwarded"

ELSE

RETURN "Request denied based on access control rules"

Process Request: This code segment manages the initial evaluation of any request sent to the BAF. Its main purpose is to determine whether the request complies with the configured access control rules before forwarding it to the blockchain node for processing:

- The key properties of the request are extracted, such as the source address, destination address and requested operation.
- The access control rules configured in the BAF are verified using these properties.
- If the rules allow the request, it is forwarded to the blockchain node, where it is processed accordingly.
- If the request does not match each rule, it is rejected, returning a response indicating that access control requirements are not met.

CHECK ACCESS CONTROL RULES (sourceAddress, destinationAddress, operation)

Load configured rules from the BAF

FOR EACH rule in the configured rules

IF the rule matches the source address, destination address, and operation

RETURN whether the rule allows access

RETURN "Denied by default" if no rules match

Check Access Control: This code segment details the process for determining whether a specific request complies with the rules configured in the BAF:

- Previously configured rules are loaded into the system from a database, blockchain, etc. These define which combinations of source, destination and transaction are allowed.
- Each rule is compared with the request details. If there is a match, a response is returned indicating whether access is granted according to that rule.

If no matching rule is found, the request is denied, following the principle of denying everything not explicitly granted.

The pseudocode for the logging mechanism (2) is:

LOG(request, response)

Create a log entry with the request, response, and current timestamp

Add the entry to the local log

IF notarization is required

Generate a hash summary of the local log

Store the hash on the blockchain

Log: This segment records all processed requests and their associated responses, ensuring traceability and auditability. In addition, it allows these records to be notarized on the blockchain to prevent tampering:

- A log entry is created that includes the request, the response and a timestamp. This entry is added to the local log.
- If notarization is required (e.g., determined by a preconfigured time interval in this case), a hash summary of the log is generated.
- This hash is stored in the blockchain, creating an immutable proof of the log.

DETERMINE IF NOTARIZATION IS REQUIRED

Return "True" if the specified time interval since the last notarization has elapsed

Determine If Notarization Is Required: This module evaluates whether the specified time interval for recording the information has elapsed. The current time is compared with that of the last record made. If the predefined interval has elapsed, the recording of the information on chain is triggered.

GENERATE HASH SUMMARY(logEntries)

Generate a hash of the selected log entries

Generate Hash Summary: This module generates a hash of the indicated records.

STORE HASH ON BLOCKCHAIN(hashSummary)

Create a transaction with the hash and send it to the blockchain

Store Hash on Blockchain: This module registers the generated hash summary in the corresponding blockchain. The hash summary of the records is sent for storage as part of a blockchain transaction.

The pseudocode for the service that restricts access to account's balances (3) is:

[7] https://github.com/pinojs/pino-http

HANDLE BALANCE QUERY(request)
IF the request is a balance query
Retrieve the balance of the account from the blockchain node
IF the balance is greater than 0
RETURN "Balance is greater than zero (1)"
ELSE
RETURN "Balance is zero (0)"
ELSE
Forward the request to the blockchain node for processing

Handle Balance Query: This module handles requests related to account balances, ensuring that privacy is respected by not revealing the exact amount, but rather a binary response as to whether the balance is greater than zero:

- If the request is a balance query, determined by the call type, the corresponding account balance is obtained from the blockchain node.
- Depending on the balance, a binary response is generated: 1 if the balance is greater than zero, or 0 if it is equal to zero.
- For any other request than a balance query, it is forwarded directly to the blockchain node for processing, as long as it does not conflict with access control rules.

IS BALANCE QUERY(request)
Check if the request type corresponds to a balance query

Is Balance Query: This module verifies whether the request corresponds to a balance query according to the type of call made to the JSON-RPC API.

GET BALANCE FROM NODE(account)
Query the blockchain node to obtain the account balance

Get Balance From Node: This module obtains the balance of an account from the blockchain node:

- The blockchain node is queried directly using the account specified in the request.
- This balance is then used to determine the binary response on whether it is greater than or equal to zero.

This basic proof-of-concept, which limits third-party access to precise account balances by only indicating whether a balance is zero or greater than zero, effectively demonstrates the core functionality of a BAF. More advanced functionalities discussed above, such as task prioritization and the use of AI for predicting potential attacks and enhancing performance, are not considered at this stage and will be considered for future work. However, these could be integrated into the same system at a later stage by updating this prototype's basic logic.

4.2.1. Experimental setup

The development scheme for this proof of concept is outlined in Fig. 3 to illustrate all the components used.

This prototype was deployed on a virtual machine on Azure. The blockchain node runs on an Azure server (B2) with 8 GB of RAM, 2 cores and 30 GB of solid-state storage (SSD), running 64-bit Ubuntu 22.04 and Besu in Docker containers. The BAF also runs on an Ubuntu 22.04 Azure server (B2) with a 2 core-CPU, 4 GB RAM and a 30 GB standard solid-state storage. The development of the BAF was carried out using Node.js. The BAF's proof-of-concept leverages a robust blockchain topology and infrastructure. Four Hyperledger Besu instances were deployed on Azure, with four validator nodes and one node dedicated to the RPC service, utilizing the Quorum Byzantine Fault Tolerance (QBTF) consensus mechanism. QBFT ensures immediate finality of transactions, dynamic validator sets, and optimal Byzantine resilience, meaning it can tolerate up to one-third of validators malfunctioning or acting maliciously. The BAF server introduced above runs the Node.js BAF middleware, ensuring efficient management and operation. Client machines included three test clients: a MacBook M1 with 8 GB RAM, a MacBook M2 with 8 GB RAM, and an HP ProBook i7-1255 U with 32 GB RAM, all connected over the Internet, with latency under 20 ms to the Azure region. This setup provided a reliable and responsive environment for testing and validating the BAF's capabilities.

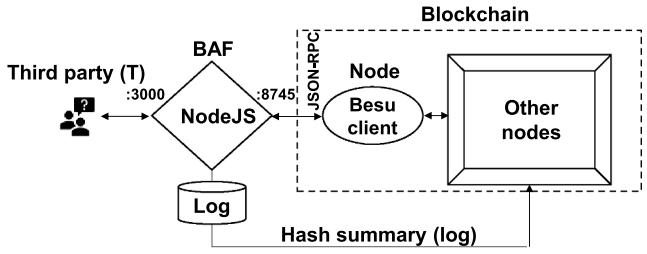


Fig. 3. BAF's proof-of-concept deployment scheme showing the interaction between user agents, the BAF, and the Besu node on Azure.

4.2.1.1. Test cases. To evaluate BAF's functionality and performance, three categories of operations were defined:

1. Access Control Mechanism
   - Every JSON-RPC request (source address, destination address, and operation) is evaluated against BAF rules.
   - Allowed requests are forwarded to the Besu node; denied requests return an error.
2. Local Log Registration & Blockchain Notarization (LRBN)
   - All requests and responses are logged locally.
   - A hash summary of the accumulated logs is generated and submitted on-chain every hour to ensure tamper-evident auditability.
3. Balance Query Privacy Service
   - For `eth_getBalance` calls, BAF intercepts and returns only a binary response:
     - "1" if balance > 0
     - "0" if balance $= 0$
   - Exact balances are never exposed through the BAF API.

Tests were conducted by sending 10 batches of transactions to the Besu's JSON-RPC node. Each batch included 100 transactions from three different client machines operating under stable network conditions. Transactions were submitted both directly to the JSON-RPC API and through the BAF API, to verify both functionality and the impact on performance that the inclusion of this component may cause.

Note that in this scenario transaction processing times are not relevant, either sent directly to Besu or through the BAF, as they depend on network's topology, its load, etc., but rather the response time differences observed due to the inclusion of the BAF in the communication pipeline.

4.3. Results

Tests were performed with 3 different computers, running macOS on Apple Silicon (2 devices) and Window's Linux subsystem (1 device). Each computer submitted a series of batch requests to the servers in Azure. The average processing times of the requests with and without involving the BAF are quite different, but the time differences are similar.

Table 1 summarizes the results of performance tests performed on three different machines. As pointed out above, each test involved sending 100 requests in 10 batches, and the roundtrip times were averaged. The test setup aimed to simulate typical client access to the blockchain node, with and without the BAF.

Thus, according to the tests performed, the BAF operation has no relevant influence in roundtrip times, which demonstrates that, even

Table 1
Average roundtrip times measured from three different client devices, comparing direct access to the blockchain node versus access through the BAF. Each device submitted 10 batches of 100 requests under similar network conditions. Results show minimal added latency when using the BAF.

Scenario	No BAF	With BAF	Difference
Apple MacBook M1 8 GB RAM	11.11 s.	11.12 s.	26.77 ms.
Apple MacBook M2 8 GB RAM	7.428 s	7.441 s.	12.89 ms
HP Probook i7–1255 U 32 GB RAM	8.607 s.	8.625 s.	17.86 ms.

including a logging module, the impact on overall system's performance is minimal. As pointed out above, the logging system was implemented using libraries that minimally interfere with the system's performance.

In the tests conducted, the BAF successfully enforced the specified requirements. When an account attempted to send a transaction that cannot interact with a particular smart contract, the system, via the BAF, responded that the interaction was not possible. Similarly, when checking the balance of an account, the BAF only indicates whether the balance is zero or greater than zero, fulfilling the proof-of-concept design. This demonstrates the BAF's ability to enhance access control and data privacy effectively.

In any case, this proof-of-concept implementation is not intended to serve as an irrefutable proof of the low influence of the BAF on overall system's performance, but only to provide evidence of the technical feasibility of the solution proposed and its limited impact on performance. Likewise, as the practical implementation discussed in this paper is just a proof-of-concept, an exhaustive safety analysis of the BAF was not carried out yet, since our purpose was to demonstrate the feasibility of the solution and its limited impact in overall system performance. In the case of a real-world implementation, the different components of the system, including the BAF, should be subjected to a safety and performance analysis.

4.4. Application example

To further clarify the BAF concept and visualize a real application beyond the proof of concept, the paragraphs below discuss an ongoing research project in which the BAF plays a relevant role in protecting the privacy of information and providing compliance with the GDPR. The research project seeks to build a functional prototype with currently available technology of this conceptual model [36]. In this article we focus on the contribution of the BAF to the resulting system, which will be developed in a consortium blockchain using Hyperledger Besu technology. Fig. 4 depicts a simplified representation of the model considering the contribution discussed below.

The state-of-the-art approaches for issuing and verifying academic records is fragmented and inefficient, often leading to the proliferation of tampered or even fake academic certificates. In this context, a blockchain-based system offering a tamper-proof solution for registering and verifying academic information was designed, making educational records easily accessible and verifiable by third parties [36]. This system is designed to be scalable and compliant with the GDPR, protecting personal data and ensuring privacy.

This approach supports the issuance, storage, and verification of various types of academic information, both formal and informal, and it allows educational institutions to generate and securely register academic data, which can then be shared with third parties as needed. Even if an institution ceases to exist, the academic data can still be verified and recovered by the data holder.

This solution is being implemented on a Hyperledger Besu permissioned consortium blockchain and combines on-chain and off-chain storage and distributes the blockchain system into interconnected blockchains to handle large volumes of transactions efficiently (cf. Fig. 4), and only non-personal information is stored on the blockchain. Because of this, and by the fact that encryption and secure channels are

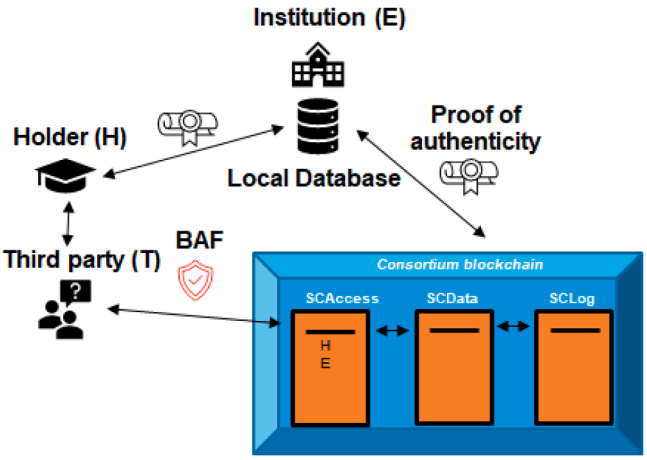


Fig. 4. This figure demonstrates the streamlined process of academic data access facilitated by the Blockchain Application Firewall (BAF) and smart contracts. It highlights the interactions between the Holder (H), Institution (E), and Third Party (T), with the Institution providing proof of authenticity from its local database. The BAF ensures secure access through a consortium blockchain, utilizing components such as SCAccess for access control, SCData for data storage, and SCLog for logging activities, thereby enhancing the security and transparency of academic data management.

used to transmit data, the model ensures that personal data is protected and complies with GDPR requirements, as discussed below (cf. Table 2). Besides, the model incorporates robust security measures to ensure data integrity, confidentiality, authentication, access control, availability, and non-repudiation. The system also logs all operations to provide accountability and traceability.

The system is also designed to be adaptable to different educational institutions without requiring changes to their existing information systems, supports a wide range of use cases, including certificate issuance, learning path registration, competence tracking, and academic credit recording.

In the proposed blockchain-based model for managing academic information, the concept of an application firewall plays a very important role for ensuring the security and privacy of educational certificates. An application firewall acts as an intermediary software module that controls access to the system, preventing unauthorized users from accessing sensitive information. This is achieved through several mechanisms integrated into the model.

In this case, the BAF functions as a gatekeeper, monitoring and filtering incoming and outgoing traffic based on predefined security rules. It ensures that only authorized users and entities can access the academic information stored within the system. By doing so, it protects the integrity and confidentiality of the data, ensuring that unauthorized access attempts are blocked and logged for further analysis.

As discussed in the previous sections, one of the primary functions of the BAF is to enforce access control policies by verifying the identity of users and entities attempting to access the system through authentication mechanisms. This includes checking credentials such as usernames, passwords, and digital certificates. Only users who have been granted the necessary permissions can proceed to access the academic information. This layer of security is essential for preventing unauthorized access and ensuring that only legitimate users can interact with the system.

The application firewall also plays a role in maintaining the confidentiality of data by ensuring that all communications between users and the system are encrypted. It uses secure channels, such as HTTPS, to transmit data, protecting it from interception and tampering during transit. This encryption ensures that even if unauthorized users manage to intercept the data, they cannot decipher it without the appropriate decryption keys.

Table 2
GDPR's key provisions and how the BAF supports compliance. Only articles that have a direct impact on BAF's features are included in this table.

Principle	How the BAF addresses this principle
Art. 5.1.b Purpose limitation.	The issuing institution and authorized third parties must use data for specific designated purposes only. BAF ensures that data within the blockchain model is not collected per se, but rather anonymized verification information of academic data. Users have full control over who can access their information and can revoke permissions at any time. Protection is ensured through two main mechanisms: firstly, data is anonymized using specific techniques when stored on the blockchain, and secondly, the verification information of academic data is not directly accessible. Access is restricted through a blockchain-based access control mechanism and the BAF, preventing external users from combining data that could potentially identify individuals, even if the data has been anonymized.
Art. 5.1.c Data minimization.	BAF is fully flexible regarding the set of fields used, ensuring that only the minimum necessary data is collected for the intended purpose. The verification information of academic data, signed by its issuers, is stored in an anonymized manner and protected through a blockchain-based access control mechanism supported by the BAF, as previously explained. This approach guarantees that data collection is limited to what is strictly necessary, enhancing privacy and compliance with GDPR regulations.
Art. 5.1.e Storage limitations.	The institution issuing personal academic information has the flexibility to delete it, when necessary, thanks to the proposed model. Data is available only as long as the user holds the relevant credentials. Users manage third-party access, deciding when to grant or revoke these rights. The BAF, along with blockchain-based access control, ensures that data is stored only for the necessary duration and under the user's control.
Art. 5.1.f Integrity and confidentiality.	The issuing institution is responsible for safeguarding the data's integrity and confidentiality. The practical solution designed does not compromise these requirements; on the contrary, it enhances them. The transparency of the blockchain reveals the origin of data issuance, and its immutability ensures that each block of information references the previous one, thereby maintaining data integrity and significantly hindering unauthorized modifications due to the unique characteristics of blockchain technology. Regarding confidentiality, the original data cannot be retrieved from the anonymized verification information. Additionally, to prevent unauthorized access to verification data, access is restricted to authorized entities only.
Art. 5.2 Accountability.	The accountability principle is addressed by designating the data controller as the issuer of the certification, which is stored on centralized servers with its authenticity notarized according to the model. All operations related to granting and revoking permissions are conducted using blockchain, which inherently records transactions immutably and identifies the senders through their private key signatures. Additionally, the BAF centrally logs access and periodically notarizes this information on the blockchain, ensuring that any data modifications are evident. This setup allows the data holder to consult this information at any time, thereby exercising their rights to grant, revoke permissions, and trace operations effectively.
Art. 16 Data modification.	The BAF allows for easy data modification, ensuring that third parties accessing the information always see the updated, accurate, complete, and correct version.
Art. 17 Right to be forgotten.	The right to be forgotten is upheld by allowing users to delete their information from the issuing entity's internal centralized databases, ensuring no personal data remains on the blockchain. While the BAF is not the central component, it plays a crucial role in GDPR compliance. The anonymization of data, combined with access control mechanisms and the BAF, prevents data exposure and unauthorized access, thereby supporting the right to be forgotten.
Art. 22 Right not to be subject to a decision based solely on automated processing.	No automated processes within or outside the blockchain. Issuing a new credential requires active creation by the issuing entity. Granting and revoking permissions are explicitly and autonomously performed by the user. Verification of data is actively conducted by the verifying entity interacting with the blockchain. Consequently, there is no automated decision-making by the initiative's promoters or third parties, as mass access to user data is prevented by the technical implementation of access control mechanisms supported by the BAF.

Another critical function of the BAF is to log and monitor all access attempts (even read requests) and activities within the system. It keeps detailed records of who accessed what information and when, providing an audit trail that can be used to detect and investigate suspicious activities. This logging capability is a key element for maintaining accountability and transparency within the system, as it allows administrators to track and respond to potential security breaches.

The application firewall also helps ensure compliance with GDPR by enforcing data protection principles such as data minimization and purpose limitation. It ensures that only the necessary data is accessed and processed by authorized users, and that personal data is not exposed to unauthorized parties. By implementing these controls, the firewall helps the system adhere to GDPR requirements, protecting the privacy rights of individuals.

In the context of the consortium blockchain-based model, the BAF is implemented by means of smart contracts (i.e., SCAccess and SCLog in Fig. 4) together with other blockchain features to provide a comprehensive security framework. The SCData smart contract in Fig. 4 above, stores the verification information of academic data. SCAccess, stores the addresses that have permission to access certain data in SCData. Fig. 4 illustrates how a given educational institution E and a data owner H are the only entities that can access the information, since they are the ones authorized to view the information in SCData. If a third-party T wanted to verify certain academic details from H, H would have to send

their academic data to T and grant T permission in SCAccess (by means of a state-modifying transaction) so that T can request from SCAccess the data that they need from SCData. The model also includes a smart contract SCLog to notarize and log all such accesses. According to the GDPR, H has the power to grant and withdraw permissions to T so that T can or cannot access academic verification data in SCData.

Thus, smart contracts enforce access control rules at the blockchain level, while the application firewall provides an additional layer of protection at the application level. This multi-layered approach ensures that academic information is protected from unauthorized access both on-chain and off-chain.

As discussed in the previous sections, Tessera would not be an appropriate solution to control the privacy of information, since private transactions between third parties T cannot be performed if they do not have their own nodes (and H and E in Fig. 4), which is unfeasible because in this application final users are mostly individuals. Note that if one or more nodes of the consortium blockchain's underlying P2P network exposes a JSON-RPC API, any registered third party T could directly request the information from SCData without the intervention of SCAccess, thus eliminating the privacy mechanism that supports GDPR compliance, among other features such as access notarization.

Indeed, another requirement of the model related to GDPR compliance is the functionality provided by SCLog, which notarize each query access to academic data. As already discussed, blockchain platforms lack native mechanisms to log accesses that do not modify the state of the chain, and consequently some kind of middleware is needed to perform this function. SCLog stores on-chain the hash summaries of log entries as a verification mechanism to prevent data manipulation.

The project under development addresses other important challenges beyond the scope of this article, but the introduction of BAF solves a problem that, otherwise, would not have a solution with the Ethereum-based technologies used.

5. Discussion

The introduction of an element like the BAF between the user and the blockchain node(s) to provide access control or, in general, to filter and restrict access to all information stored on chain might initially seem to contradict the very nature of blockchain technology. In blockchain, the reliability of decentralized information is ensured by allowing all users to access all information. This is true to some extent, but it is also true that in enterprise or private applications, confidentiality and access control are key factors to consider, with existing solutions to support these features.

On the other side, this proposal does not significantly limit the mentioned key property of blockchain technology, as all nodes in any private or consortium blockchain still retain all the information managed (i.e., every node has a full copy of the chain). This maintains the trust added by decentralization. Additionally, by appropriately configuring access control permissions, certain roles, such as administrators, auditors, or other designated parties, can have access to all information for control purposes, although in a controlled manner. Note that applying a BAF to a public blockchain is not practical, since anyone can add a node to the blockchain network and thus access all data, and therefore is specially designed for private or consortium blockchains.

The BAF approach, which enhances data privacy and allows for selective information sharing based on users' roles, whether integrated with a digital identity system or not, opens new opportunities and use cases in the enterprise sector. In such environments, protecting information and ensuring compliance with data protection laws are critical requirements and these features cannot be achieved with current Ethereum-based platforms because private transactions are supported among nodes only and not at the user agent level (i.e., individual users or smart contracts).

Let us consider the real application use case discussed above where academic data is managed that should be kept protected selectively to some users participating in a permissioned blockchain, according to access permits granted to individual users. Permissioned blockchains such as Hyperledger Besu, GoQuorum and similar initiatives offer a basic level of access control and manage access to information through private transactions using Tessera, but they do operate among nodes. In contrast, BAF enables dynamic modification of access rules in real time among users, without the need to stop or reconfigure the blockchain system. This is especially useful in enterprise environments where access control policies are complex and can change over time, even frequently, due to organizational changes, as the use case illustrates, or regulatory requirements. Continuing with the example, if new academic information is introduced in the system or new users are added, the system can adjust access rules to user requirements immediately by means of the BAF, allowing only the new users to access to specific records, without compromising security. This ensures that temporary and dynamic accesses are managed efficiently and securely.

Note that the ability to validate transactions while preserving privacy could help to address GDPR compliance by ensuring that minimal data is exposed during the validation processes. However, although the access control mechanisms introduced by BAF to enhance data privacy contribute to better meet GDPR requirements, it does not guarantee fully compliance, as other issues such as the right to be forgotten, data deletion or portability need to be specifically addressed. The BAF primarily addresses privacy concerns related to access control. In the actual application described, there are mechanisms specifically introduced to make the resulting system fully compliant with the GDPR, in a context where the BAF plays a necessary but not sufficient role.

Another relevant characteristic related to the registration of access to information is that, with the introduction of the BAF, queries to information stored on the blockchain can also be logged, which cannot be done directly on the blockchain with the default approach, as discussed in Sect. 3. These logs can be easily notarized, adding an additional layer of trust by certifying that only those with access to the data can indeed query it. This is of particular value in the case of applications in which, for legal or regulatory reasons, any access to information must be logged, apart from the modification of information records, which is provided by the blockchain itself, as discussed in Sect. 3.

Moreover, if the BAF is equipped with the necessary tools and functions, it can significantly enhance the overall system's performance, scalability, and security. This can be achieved through caching mechanisms, prioritizing certain accounts or transactions, protecting against attacks or attempts to slow down the system via malicious query flooding, or even mitigating the consequences of smart contract failures through version control managed by the BAF. These features are by no means intended to replace the native functionalities of the blockchain, but only to complement and improve them with an external element to further improve the resulting overall system.

A possible further enhancement to the BAF is the incorporation of privacy-preserving cryptographic techniques, such as the Pedersen Commitment, which allow transaction validation without revealing their full details. This aligns with the BAF's goal of protecting sensitive information while controlling access. For example, the BAF could validate information such as account balances, ensuring that data meets specific criteria without exposing actual values. The integration of such cryptographic techniques would significantly strengthen the privacy features of BAF, especially in enterprise use cases where regulatory compliance and data confidentiality are critical.

Starting from the premise that not all users will have access to all information, but only those who are duly authorized, and considering that nodes still maintain all the data, a blockchain platform with a BAF can be seen as an open system restricted to certain accounts. However, a notable drawback is the introduction of a centralizing entity, as access to the information stored in blockchain transactions is only possible through a BAF, creating a single point of failure. While this introduces a level of centralization, it is important to note that accessing data through a specific node also centralizes access to some extent.

However, it can be argued that if the BAF acts as an intermediary between users and the blockchain containing potentially valuable data, it could become a target for attackers or even be compromised, allowing access to the underlying data and services to be controlled, contradicting the principles of decentralization.

To address this issue, there are several strategies that can be implemented to mitigate the risks associated with a single point of failure. Instead of relying on a single instance of the BAF, multiple instances can be deployed on different nodes of the blockchain network. This would distribute the load and ensure that no single instance of the BAF has sole control over access. By distributing the BAF, the system can prevent bottlenecks and reduce the risks associated with a centralized access control mechanism.

The BAF can also be designed with built-in redundancy and fault tolerance. For example, a failover system could be implemented, where secondary instances of the BAF take over if the primary instance fails. This ensures continuous operation and minimizes downtime, reducing the likelihood of a total system failure.

BAF programming and configuration play a key role in maintaining access control, privacy and overall security of the entire solution. Errors or misconfigurations in the rules or their modes of operation may lead to unexpected consequences, such as improper data access, privacy issues, performance problems, and even security vulnerabilities. Therefore, this element must be programmed with the highest security standards and regular security audits, combined with real-time monitoring and logging, as they can help detect security incidents if BAF is compromised. In addition, the logging system should periodically store hash summaries of records on the blockchain, as proposed in this paper, providing an immutable record of access requests and helping to identify any unauthorized modifications or malicious behavior.

These strategies ensure that, while BAF introduces an intermediate element to improve access control, it does not compromise the principle of decentralization. By distributing BAF instances, the system can maintain its resilience to failures and attacks, ensuring continuous and secure access to data and services on the blockchain.

It is also important to remember that only a few entry points (i.e., BAF, nodes) are centralized for information access, but data remains available regardless of the presence of one or several BAFs.

Although the BAF offers significant improvements in privacy and access control, its implementation could involve technical challenges, such as efficient cache management in networks with high concurrency or its integration with identity management systems in complex enterprise environments. These aspects should be explored in future work to optimize its performance and adaptability.

The application example introduced in Sect. 4.4 exemplifies how the BAF can be applied in a real-world scenario to address specific limitations of enterprise blockchain technologies. The BAF's ability to dynamically channel requests based on access rules and ensure data privacy across accounts represents an efficient solution to GDPR compliance in applications such as academic data verification. Unlike existing tools such as Tessera, which requires each user to have their own node to implement private transactions, the BAF enables a more flexible approach by operating at the account level.

5.1. Ethical considerations

While the Blockchain Application Firewall enhances privacy and access control, it introduces ethical considerations that must be addressed. Specifically, increasing privacy mechanisms can reduce transparency for third parties, regulators, or even system administrators if certain information is not accessible to all relevant parties. Over-reliance on filtering mechanisms could hinder legitimate audits or oversight if appropriate security measures are not implemented. For example, overly aggressive access filtering could obscure behaviors relevant to fraud detection or forensic analysis.

To address these issues, BAF implementations may include configurable audit channels and policy-based exception management. For instance, greater privileges could be granted to legally authorized parties, or selective unmasking mechanisms could be introduced by court order or verified institutional processes. Note that a key design principle of BAF is flexibility, allowing developers to align technical applications with organizational ethics.

Additionally, it is important to consider that BAF centralizes access to information, which, if compromised, could pose a security risk. Therefore, BAF components must be carefully designed, constructed and audited to ensure their primary benefits do not become additional problems for the organization using them.

Moreover, combining the integrity and transparency potential of distributed ledger technologies with a tool like BAF, which enables access control (potentially governed by rules defined on a blockchain), opens new ethical usage options in enterprise projects. This combination helps comply with GDPR and comparable regulations, which aim to protect user data privacy dynamically and reliably. In this context, BAF emerges as a solution that enhances compliance efforts.

6. Conclusions

This paper discussed in detail the concept of a Blockchain Application Firewall to address some of the key limitations of blockchain technology, specifically regarding privacy, dynamic access control, and security in scenarios where private transactions must be supported at the user agent level and not the node level, which is what solutions such as Tessera in GoQuorum or Hyperledger Besu.

The BAF is not intended to replace existing access control mechanisms in permissioned blockchains, but to complement and enhance them. It provides an additional layer of security that enables more flexible and detailed management of access permissions, which is particularly valuable in scenarios where protection of sensitive data and regulatory compliance are of paramount importance and the restrictions must be defined at user level.

Therefore, implementing a BAF adds a layer of data protection, dynamic access control, and enhances the scalability and security of Ethereum blockchain-based applications in the considered scenarios, regardless of their actual implementation, by acting as an intermediate element to improve the overall system.

Another functionality provided by the BAF not natively available in blockchain platforms is the logging of read-only operations, which in certain use cases such as the one discussed in Sect. 4.4 may be necessary. This ability to audit and log accesses supports full traceability of all activities performed with the blockchain, both writing, supported by the platform itself, and reading through this middleware.

The BAF also supports the integration with privacy-preserving cryptographic techniques and can be integrated with identity management systems, ensuring that only authenticated and authorized users gain access to sensitive blockchain data, thereby strengthening the overall security of the platform. Although in permissioned platforms users are usually identified, this would allow to integrate these accounts with digital identities such as those provided by the eIDAS framework[8] or Decentralized Identifiers (DIDs [54]), widely used in blockchain environments.

BAF enhances security by filtering and blocking suspicious transactions, protecting against DDoS attacks, and ensuring reliable operation. It improves performance through caching, reduces latency, and optimizes scalability by prioritizing requests. The BAF's potential to integrate AI for predictive security and task prioritization, although not in the initial proof-of-concept, showcases its versatility. Additionally, it simplifies smart contract version management, enabling secure updates without disrupting operations, thus maintaining blockchain system adaptability and reliability.

[8] https://digital-strategy.ec.europa.eu/en/policies/eidas-regulation

The proof-of-concept demonstrated that the BAF could effectively restrict access to certain blockchain data without compromising the decentralized nature of the platform. By intercepting user requests and applying predefined rules, the BAF can control the information returned to the user, such as indicating whether an account balance is zero or greater than zero, rather than providing the exact amount. This selective transparency enhances data privacy and meets regulatory requirements for data protection. Moreover, the BAF can log and notarize access requests, adding an additional layer of security and traceability that is not natively available in standard blockchain implementations.

While the Blockchain Application Firewall (BAF) deviates from the fully decentralized model of Bitcoin, it addresses the need for privacy and access control in business environments, especially concerning personal data protection under GDPR. Despite potential transparency issues, BAF offers a more private, scalable, secure, and reliable alternative, leveraging blockchain's inherent trustworthiness. Deploying multiple BAFs across nodes distributes access control, preventing single points of failure and ensuring data security and availability even if some BAFs are compromised.

Beyond the technical contributions, the BAF also carries significant potential for real-world impact in addition to the case of the issuance and validation of academic certificates already discussed in the article. For example, in the healthcare domain, BAF can serve as a privacy-preserving gateway for accessing electronic health records stored on a permissioned blockchain, ensuring that only authorized actors (e.g., specific physicians) access sensitive data while preserving a verifiable access log. The auditability features directly support regulatory compliance, such as GDPR or HIPAA in clinical environments. Another use case in the same sector could be that patients could, for example, grant access to anonymous medical information directly to researchers so they have more data to analyze and predict diseases or health problems.

In the financial sector, the BAF can enable fine-grained access control to account balances and transaction history according to the different roles at account level. This is especially relevant in contexts where third-party financial platforms interact with user wallets, such as in decentralized finance (DeFi) or bank integrations. BAF reduces data exposure while retaining operational efficiency. The BAF could also be used in the supply chain industry, where access to specific actors could be granted or not depending on their roles and responsibilities.

In the three scenarios above, the system's flexibility, logging, and cryptographic guarantees open a new path for deploying blockchain-based services in privacy-critical domains, bridging the gap between transparency and data protection.

In general, it can be argued that the BAF concept aligns very well with any use case where granular access control at the account level, rather than the node level, is required, leveraging the trust provided by a blockchain-based system.

In conclusion, the BAF represents a significant step forward in enhancing the security, privacy, logging, performance and other features of Ethereum-based blockchain platforms where information must remain private among certain accounts and not at node level. By addressing the inherent limitations of blockchain technology, the BAF opens new possibilities for its application in enterprise environments, where data protection and regulatory compliance are paramount. However, further research is needed to optimize the performance and effectiveness of BAFs, as well as to address specific challenges related to scalability and performance in high-traffic environments. Future work will focus on integrating advanced functionalities and further testing to ensure the BAF meets the highest security standards and performs efficiently in diverse scenarios. Specifically, in the short term, the BAF is being developed to create a Minimum Viable Product (MVP) for the use case described in Sect. 4.2 according to the model proposed in [36] and beyond this initial approach already developed using NFTs [55], which relates to the issuance and validation of academic information in compliance with the GDPR. As previously discussed, the BAF plays a highly relevant role in ensuring such compliance.

Therefore, beyond the proof of concept carried out and discussed in this paper, the BAF is being further developed to enable selective data queries and to provide notarization functions for read-access events to data stored on a blockchain, effectively notarizing these accesses. This is a real-world project that aims to go beyond an MVP in the future, which is why the design and development of the BAF must adhere to the highest security standards and best practices. In the development of this MVP, we plan to perform load testing on the BAF and intensively notarize read access.

CRediT authorship contribution statement

Christian Delgado-von-Eitzen: Writing – review & editing, Writing – original draft, Visualization, Validation, Supervision, Software, Resources, Project administration, Methodology, Investigation, Formal analysis, Data curation, Conceptualization. **Manuel José Fernández-Iglesias:** Writing – review & editing, Writing – original draft, Visualization, Validation, Supervision, Resources, Project administration, Methodology, Investigation, Formal analysis, Data curation, Conceptualization. **Luis Anido-Rifón:** Writing – review & editing, Visualization, Validation, Supervision, Resources, Project administration, Methodology, Investigation, Funding acquisition. **Fernando A. Mikic-Fonte:** Writing – review & editing, Visualization, Validation, Supervision, Methodology, Investigation.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgement

Funding: Grant TED2021–130828B-I00 funded by MCIN/AEI/10.13039/501100011033 and European Union NextGenerationEU/PRTR. Funding for open access charge: Universidade de Vigo/CISUG. We would like to express our gratitude to the members of the GAVIN team at atlanTTic, María Ruiz-Molina and Pablo Molina-Martínez, for their comments and insight.

Data availability

Data will be made available on request.

References

[1] S. Nakamoto, Bitcoin: a peer-to-peer electronic cash system, (2008). https://doi.org/10.2139/ssrn.3440802.
[2] F. Fang, C. Ventre, M. Basios, L. Kanthan, D. Martinez-Rego, F. Wu, L. Li, Cryptocurrency trading: a comprehensive survey, Financ. Innov. 8 (2022) 13, https://doi.org/10.1186/s40854-021-00321-6.
[3] H. Taherdoost, Smart contracts in blockchain technology: a critical review, Information 14 (2023), https://doi.org/10.3390/info14020117.
[4] V. Buterin, A next-generation smart contract and decentralized application platform, White Pap. 3 (2014) 2. –1.
[5] A.M. Antonopoulos, G. Wood, Smart contracts and solidity, in: Mastering Ethereum Build. Smart Contract. DApps, 1st, 95472, O'Reilly Media, 1005 Gravenstein Highway North, Sebastopol, CA, 2019, pp. 127–160.
[6] V.T. Truong, L. Le, D. Niyato, Blockchain meets metaverse and digital asset management: a comprehensive survey, IEEE Access 11 (2023) 26258–26288, https://doi.org/10.1109/ACCESS.2023.3257029.
[7] J. Sunny, N. Undralla, V. Madhusudanan Pillai, Supply chain transparency through blockchain-based traceability: an overview with demonstration, Comput. Ind. Eng. 150 (2020) 106895, https://doi.org/10.1016/j.cie.2020.106895.
[8] C. Delgado-von-Eitzen, L. Anido-Rifón, M.J. Fernández-Iglesias, Blockchain applications in education: a systematic literature review, Appl. Sci. 11 (2021), https://doi.org/10.3390/app112411811.
[9] M. Al-Zubaidie, R.H. Razzaq, Maintaining security of patient data by employing private blockchain and fog computing technologies based on internet of medical things, Informatica 48 (2024), https://doi.org/10.31449/inf.v48i12.6047.

[10] M. Al-Zubaidie, W. Jebbar, Transaction security and management of blockchain-based smart contracts in E-banking-employing microsegmentation and yellow saddle goatfish, Mesopotamian J. CyberSecurity 4 (2024) 1–19, https://doi.org/10.58496/MJCS/2024/005.
[11] D. Kondratiuk, P.L. Seijas, A. Nemish, S. Thompson, Standardized crypto-loans on the cardano blockchain, in: M. Bernhard, A. Bracciali, L. Gudgeon, T. Haines, A. Klages-Mundt, S. Matsuo, D. Perez, M. Sala, S. Werner (Eds.), Financ. Cryptogr. Data Secur. FC 2021 Int. Work, Springer Berlin Heidelberg, Berlin, Heidelberg, 2021, pp. 579–594, https://doi.org/10.1007/978-3-662-63958-0_41.
[12] F. Schär, Decentralized finance: on blockchain- and smart contract-based financial markets, Fed. Reserv. Bank St. Louis Rev. 103 (2021), https://doi.org/10.20955/r.103.153-74.
[13] S. Aggarwal, N. Kumar, Hyperledger, in: S. Aggarwal, N. Kumar, P. Raj (Eds.), Blockchain Technol. Secur. Smart Appl. Across Ind. Verticals, Elsevier, 2021, pp. 323–343, https://doi.org/10.1016/bs.adcom.2020.08.016.
[14] E. Androulaki, A. Barger, V. Bortnikov, C. Cachin, K. Christidis, A. De Caro, D. Enyeart, C. Ferris, G. Laventman, Y. Manevich, S. Muralidharan, C. Murthy, B. Nguyen, M. Sethi, G. Singh, K. Smith, A. Sorniotti, C. Stathakopoulou, M. Vukolić, S.W. Cocco, J. Yellick, Hyperledger fabric: a distributed operating system for permissioned blockchains, in: Proc. Thirteen. EuroSys Conf, Association for Computing Machinery, New York, NY, USA, 2018, pp. 1–15, https://doi.org/10.1145/3190508.3190538.
[15] C. Fan, C. Lin, H. Khazaei, P. Musilek, Performance analysis of hyperledger Besu in private blockchain, in: 2022 IEEE Int. Conf. Decentralized Appl. Infrastructures, 2022, pp. 64–73, https://doi.org/10.1109/DAPPS55202.2022.00016.
[16] A. Baliga, I. Subhod, P. Kamat, S. Chatterjee, Performance Evaluation of the Quorum Blockchain Platform, 2018. https://arxiv.org/abs/1809.03421.
[17] ConsenSys, Tessera. https://github.com/ConsenSys/tessera, 2024.
[18] P. Voigt, A. Von dem Bussche, The EU General Data Protection Regulation (GDPR), Springer, Cham, 2017, https://doi.org/10.1007/978-3-319-57959-7.
[19] R. Metere, C. Dong, Automated cryptographic analysis of the pedersen commitment scheme, in: J. Rak, J. Bay, I. Kotenko, L. Popyack, V. Skormin, K. Szczypiorski (Eds.), Comput. Netw. Secur, Springer International Publishing, Cham, 2017, pp. 275–287.
[20] W.Y. Chiu, W. Meng, BlockFW – Towards blockchain-based rule-sharing firewall, in: Procs. 16th Int. Conf. Emerg. Secur. Information, Syst. Technol. (SECURWARE 2022), 2023, pp. 70–75, https://doi.org/10.48550/arXiv.2303.13073.
[21] G. Zyskind, O. Nathan, A. "Sandy" pentland, decentralizing privacy: using blockchain to protect personal data, in: 2015 IEEE Secur. Priv. Work., 2015, pp. 180–184, https://doi.org/10.1109/SPW.2015.27.
[22] D. Di Francesco Maesa, P. Mori, L. Ricci, Blockchain based access control, in: L. Y. Chen, H.P. Reiser (Eds.), Distrib. Appl. Interoper. Syst, Springer International Publishing, Cham, 2017, pp. 206–220, https://doi.org/10.1007/978-3-319-59665-5_15.
[23] D. Di Francesco Maesa, P. Mori, L. Ricci, Blockchain based access control services, in: 2018 IEEE Int. Conf. Internet Things IEEE Green Comput. Commun. IEEE Cyber, Phys. Soc. Comput. IEEE Smart Data, 2018, pp. 1379–1386, https://doi.org/10.1109/Cybermatics_2018.2018.00237.
[24] D. Di Francesco Maesa, P. Mori, L. Ricci, A blockchain based approach for the definition of auditable access control systems, Comput. Secur. 84 (2019) 93–119, https://doi.org/10.1016/j.cose.2019.03.016.
[25] L. Xu, I. Markus, S. I, N. Nayab, Blockchain-based access control for enterprise blockchain applications, Int. J. Netw. Manag. 30 (2020), https://doi.org/10.1002/nem.2089.
[26] R.L. Rivest, A. Shamir, Y. Tauman, How to leak a secret: theory and applications of ring signatures, in: O. Goldreich, A.L. Rosenberg, A.L. Selman (Eds.), Theor. Comput. Sci. Essays Mem. Shimon Even, Springer Berlin Heidelberg, Berlin, Heidelberg, 2006, pp. 164–186, https://doi.org/10.1007/11685654_7.
[27] M.R. Ghazi, D. Gangodkar, Hadoop, MapReduce and HDFS: a developers perspective, Procedia Comput. Sci. 48 (2015) 45–50, https://doi.org/10.1016/j.procs.2015.04.108.
[28] R.G. Brown, The Corda Platform: An Introduction, White Pap, 2018. https://r3.com/wp-content/uploads/2018/05/corda-platform-whitepaper.pdf.
[29] S. Tikhomirov, Ethereum: State of Knowledge and Research Perspectives, in: A. Imine, Fern, J.M. ez, J.-Y. Marion, L. Logrippo, J. Garcia-Alfaro (Eds.), Cham, Springer International Publishing, n.d.: pp. 206–221. https://doi.org/10.1007/978-3-319-75650-9_14.
[30] D.A. Zetzsche, D.W. Arner, R.P. Buckley, Decentralized finance, J. Financ. Regul. 6 (2020) 172–203, https://doi.org/10.1093/jfr/fjaa010.
[31] K. Wu, Y. Ma, G. Huang, X. Liu, A first look at blockchain-based decentralized applications, Softw. Pract. Exp. 51 (2021) 2033–2050, https://doi.org/10.1002/spe.2751.
[32] T. Hardjono, A. Pentland, Verifiable anonymous identities and access control in permissioned blockchains, ArXiv (2019), https://doi.org/10.48550/arXiv.1903.04584, 1903.04584.
[33] D. Čapko, S. Vukmirović, N. Nedić, State of the art of zero-knowledge proofs in blockchain, in: 2022 30th Telecommun. Forum, 2022, pp. 1–4, https://doi.org/10.1109/TELFOR56187.2022.9983760.
[34] A. Alniamy, B.D. Taylor, Attribute-based access control of data sharing based on hyperledger blockchain, in: Proc. 2020 2nd Int. Conf. Blockchain Technol, Association for Computing Machinery, New York, NY, USA, 2020, pp. 135–139, https://doi.org/10.1145/3390566.3391688.
[35] Z. Qiao, S. Liang, S. Davis, H. Jiang, Survey of attribute based encryption, in: 15th IEEE/ACIS Int. Conf. Softw. Eng. Artif. Intell. Netw. Parallel/Distributed Comput., 2014, pp. 1–6, https://doi.org/10.1109/SNPD.2014.6888687.
[36] C. Delgado-von-Eitzen, L. Anido-Rifón, M.J. Fernández-Iglesias, Application of blockchain in education: gdpr-compliant and scalable certification and verification of academic information, Appl. Sci. 11 (2021), https://doi.org/10.3390/app11104537.
[37] European Parliament: Directorate-General for Parliamentary Research Services, M. Finck, Blockchain and the general data protection regulation. Can Distributed Ledgers Be Squared With European Data Protection Law?, Publications Office of the European Union, 2019. https://data.europa.eu/doi/10.2861/535.
[38] T. Lyons, L. Courcelas, K. Timsit, Blockchain and the GDPR, The European Union Blockchain Observatory and Forum, 2018. https://blockchain-observatory.ec.europa.eu/document/download/b3a919ed-0045-46f8-89de-f23ca140e037_en?filename=20181016_report_gdpr.pdf.
[39] M. Jemel, A. Serhrouchni, Decentralized access control mechanism with temporal dimension based on blockchain, in: 2017 IEEE 14th Int. Conf. E-Bus. Eng, 2017, pp. 177–182, https://doi.org/10.1109/ICEBE.2017.35.
[40] J.P. Cruz, Y. Kaji, N. Yanai, RBAC-SC: role-based access control using smart contract, IEEE Access 6 (2018) 12240–12251, https://doi.org/10.1109/ACCESS.2018.2812844.
[41] M. Steichen, S. Hommes, R. State, ChainGuard — A firewall for blockchain applications using SDN with OpenFlow, in: 2017 Princ. Syst. Appl. IP Telecommun., 2017, pp. 1–8, https://doi.org/10.1109/IPTCOMM.2017.8169748.
[42] L. Bennis, S. Benhlima, Toward a new approach: extending a game-based learning authoring tool eAdventure to multiple mobile devices, in: A. Rocha, M. Serrhini, C. Felgueiras (Eds.), Eur. MENA Coop. Adv. Inf. Commun. Technol, Springer International Publishing, Cham, 2017, pp. 47–56, https://doi.org/10.1007/978-3-319-46568-5_5.
[43] W.K. Härdle, C.R. Harvey, R.C.G. Reule, Understanding cryptocurrencies, J. Financ. Econom. 18 (2020) 181–208, https://doi.org/10.1093/jjfinec/nbz033.
[44] M. Mazzoni, A. Corradi, V. Di Nicola, Performance evaluation of permissioned blockchains for financial applications: the consensys quorum case study, Blockchain Res. Appl. 3 (2022) 100026, https://doi.org/10.1016/j.bcra.2021.100026.
[45] ConsenSys, Quorum Whitepaper, White Pap. https://github.com/Consensys/quorum-docs/blob/master/Quorum.Whitepaper.v0.2.pdf, 2018.
[46] S. Madakam, R. Ramaswamy, S. Tripathi, Internet of Things (IoT): a literature review, J. Comput. Commun. (2015) 164–173, https://doi.org/10.4236/jcc.2015.35021.
[47] H. Hasrouny, A.E. Samhat, C. Bassil, A. Laouiti, VANet security challenges and solutions: a survey, Veh. Commun. 7 (2017) 7–20, https://doi.org/10.1016/j.vehcom.2017.01.002.
[48] X. Wu, Z. Zou, D. Song, Ethereum tools and frameworks. Learn Ethereum Build Your Own Decentralized Appl. With Ethereum Smart Contract, Packt, 2019, pp. 294–335.
[49] H. Wang, J. Liao, Blockchain privacy protection algorithm based on pedersen commitment and zero-knowledge proof, in: Proc. 2021 4th Int. Conf. Blockchain Technol. Appl., Association for Computing Machinery, New York, NY, USA, 2022, pp. 1–5, https://doi.org/10.1145/3510487.3510488.
[50] R. Deepalakshmi, R. Vijayalakshmi, C. Sam Ruben, R. Pandiya Rajan, J. Pradeep, Application of artificial intelligence in cybersecurity: a detailed survey on intrusion detection systems, in: S. Pramanik, A. Sharma, S. Bhatia, D.-N. Le (Eds.), An Interdiscip. Approach to Mod. Netw. Secur, CRC Press, 2022, pp. 1–22, https://doi.org/10.1201/9781003147176-1.
[51] A. Ouaddah, A.A. Elkalam, A.A. Ouahman, Towards a novel privacy-preserving access control model based on blockchain technology in IoT, in: A. Rocha, M. Serrhini, C. Felgueiras (Eds.), Eur. MENA Coop. Adv. Inf. Commun. Technol., Springer International Publishing, 2017, pp. 523–533, https://doi.org/10.1007/978-3-319-46568-5_53.
[52] S. Verma, N. Gupta, Application of artificial intelligence in cybersecurity, in: H. S. Saini, R. Sayal, R. Buyya, G. Aliseri (Eds.), Innov. Comput. Sci. Eng. Proc. 7th ICICSE, Springer Singapore, Singapore, 2020, pp. 65–72, https://doi.org/10.1007/978-981-15-2043-3_9.
[53] A.M. Antonopoulos, G. Wood, Mastering ethereum, in: Building Smart Contracts and DApps, 1st ed., 95472, O'Reilly Media, Sebastopol, CA, 2019, pp. 297–318, 1005 Gravenstein Highway North.
[54] C. Brunner, U. Gallersdörfer, F. Knirsch, D. Engel, F. Matthes, DID and VC: untangling decentralized identifiers and verifiable credentials for the web of trust, in: Proc. 2020 3rd Int. Conf. Blockchain Technol. Appl., Association for Computing Machinery, New York, NY, USA, 2021, pp. 61–66, https://doi.org/10.1145/3446983.3446992.
[55] C. Delgado-von-Eitzen, L. Anido-Rifón, M.J. Fernández-Iglesias, NFTs for the issuance and validation of academic information that complies with the GDPR, Appl. Sci. 14 (2024), https://doi.org/10.3390/app14020706.

Christian Delgado-von Eitzen has a Master's in Telecommunication Engineering degree from the University of Vigo, specialized in information security and blockchain. Presently his is involved in R&D activities in emerging e-learning technologies with the Department of Telematic Engineering at University of Vigo.

Manuel J. Fernández-Iglesias Manuel José Fernández-Iglesias has a degree in Telecommunications Engineering (1990) from the University of Santiago de Compostela and a PhD in Telecommunications Engineering (1997) from the University of Vigo. Since 1990 he has been a lecturer at the School of Telecommunications Engineering in Vigo, currently serving as a full professor in the Department of Telematics Engineering at the University of Vigo and as a senior researcher at atlanTTic Research Center. He has more than a hundred international publications in the field of information and communication technologies,

and regularly participates in international projects with companies and institutions in the ICT sector. His research activity focuses on advanced telecommunication solutions for education, for the elderly and for the care of dependent people.

Luis Anido-Rifón has a Telecommunication Engineering degree with honors (1997) in the Telematics and Communication branches and a Telecommunication Engineering PhD with honors (2001) by the University of Vigo. Currently, he is Full Professor in the Telematics Engineering Department of the University of Vigo. He has received several awards by the W3C, the Royal Academy of Sciences and the Official Spanish Telecommunication Association. He has authored >200 papers in journals and conferences and >100 research projects including several funded by the European Commission. This author became a Senior Member (SM) in 2015.

Fernando A. Mikic Fonte received the M.Sc. and Ph.D. degrees in telecommunication engineering from the University of Vigo, in 2001 and 2010, respectively. He is currently an Associate Professor with the Engineering School of Telecommunication, University of Vigo, where he is also with the Group of Telematics Systems Engineering (GIST), Telematics Engineering Department. His current research assignments, carried out with the atlanTTic Research Center for Telecommunication Technologies, include e-learning, serious games, e-health, and artificial intelligence.